EXIF Metadata Privacy Testing

Educational Bug Bounty Series • Authorized Security Research Only

■ Image EXIF Metadata Exposure — Privacy Testing

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope and ethics: *Use images you own or synthetic samples. Never publish a person's precise location or private device details.*

■ Executive Summary

Images may contain EXIF metadata such as GPS coordinates, device make/model, software details, and timestamps. The supplied one-page PDF describes a privacy risk when uploaded images are served without stripping sensitive metadata.

■ Core Testing Methodology

1. Identify an authorized image-upload feature.
2. Use an owned or synthetic image with known, non-sensitive metadata.
3. Upload through the normal workflow with a test account.
4. Retrieve only your own uploaded image.
5. Inspect metadata locally with a trusted EXIF viewer.
6. Compare the source image with the uploaded/downloaded version.
7. Redact coordinates, serial numbers, and private device details from evidence.
8. Report and retest after remediation.

■ High-Value Bug Bounty Tips & Edge Cases

• GPS metadata may reveal latitude and longitude.

• Device/software fields can disclose details about the uploader's environment.

• Thumbnail generation may strip some fields but leave others.

• The original file may retain metadata even when a preview is sanitized.

• Metadata exposure and unauthorized image access are separate issues.

• The source outlines sample-image testing but does not establish a flaw in a specific service.

■■ Educational Checklists & Safe Examples

```
Target: [Your-Domain]
Test account: [Controlled-Test-Account]
Image: [Synthetic-or-Owned-Image]
Metadata before upload: [Known test fields]
Metadata after download: [Present / Removed / Partial]
Sensitive values: [Redacted]
```

• [ ] GPS and unnecessary EXIF fields are removed where appropriate.

• [ ] Thumbnails and originals follow the same privacy policy.

• [ ] Original uploads are access-controlled.

• [ ] Reports redact all sensitive metadata.

■■ Mitigation & Remediation

Strip GPS and unnecessary EXIF/XMP metadata during upload or processing, re-encode images using maintained libraries, apply the policy to thumbnails and originals, protect original files, and add automated tests using synthetic images.

Source Notes

Based on the supplied one-page *meta data not extracted.pdf*. It describes checking an uploaded image URL with an EXIF viewer and references sample images and a metadata-inspection site.

Educational use only. Protect personal data.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.